

QA Report 06: Partner Gateway & Edge Security

Project: OneCluster UBN Platform **Report ID:** QA-RPT-006 **Sprint Period:** March 31 - April 9, 2026 **Prepared By:** QA Team **Date:** April 9, 2026 **Status:** BLOCKED (Dev Environment)

1. Executive Summary

This report covers quality assurance testing for the Partner Gateway and Edge Security layer of the UBN platform. The gateway serves as the primary entry point for all partner API traffic and enforces authentication, rate limiting, circuit breaking, and sandbox isolation.

During this sprint, 23 commits were merged including BFF route additions, JWT authentication on BFF routes, and audience validation disabling for unified auth. Production gateway testing passed all 23 test cases successfully. However, the dev environment gateway is returning 502 errors across all endpoints (CRITICAL issue PEG-375), blocking all dev-environment validation. This is the highest-priority issue for the platform team.

2. Scope

Components Under Test

Component	Description
API Key Authentication	Argon2id hashed API key validation
JWT Authentication	RS256 signed JWT token verification
mTLS	Mutual TLS for partner-to-gateway communication
Rate Limiting	Token bucket algorithm with 3-level enforcement
Circuit Breaker	Failure threshold detection and automatic recovery
Sandbox Mock Middleware	Request interception for sandbox environment responses
Pilot Gate Middleware	Feature-flag-based route access control
Session Concurrency	Per-IP session management with 60s TTL
BFF Routes	Backend-for-Frontend route proxying

Rate Limiting Tiers

Tier	Limit	Scope
Per-Product	1,000 requests/hour	Individual API product
Per-Partner	5,000 requests/hour	Partner organization aggregate
System-Wide	500,000 requests/hour	Global platform capacity

Circuit Breaker Configuration

- Failure Threshold:** 5 failures within 30 seconds
- State Transition:** CLOSED -> OPEN -> HALF-OPEN -> CLOSED
- Open State Response:** HTTP 503 Service Unavailable
- Recovery Window:** 30 seconds in HALF-OPEN before full reset

3. Changes This Sprint

Total Commits: 23

Change	Description	Impact
BFF routes added	New Backend-for-Frontend route definitions for portal proxying	Medium — new traffic paths through gateway
JWT auth on BFF routes	RS256 JWT validation applied to all BFF endpoints	High — security enforcement on new routes
Audience validation disabled	Unified auth flow no longer validates JWT aud claim	High — security trade-off for multi-portal support
Gateway configuration updates	Upstream service routing and timeout adjustments	Medium — affects request forwarding behavior

Security Consideration

Disabling audience validation on JWT tokens is a deliberate trade-off to support unified authentication across Admin and Partner portals. The team should document the compensating controls (IP allowlisting, session concurrency limits) and revisit this decision before GA launch.

4. Test Results

4.1 Production Gateway Tests

Environment: Production Gateway Result: 23/23 PASS

Test ID	Test Case	Expected	Actual	Status	Notes
GW-001	Valid API key authentication (Argon2id)	200 OK with authenticated context	200 OK	PASS	Key hashed and matched correctly
GW-002	Invalid API key rejection	401 Unauthorized	401 Unauthorized	PASS	Error message does not leak key format
GW-003	Expired API key rejection	401 Unauthorized	401 Unauthorized	PASS	Expiry enforced at gateway layer
GW-004	Valid JWT RS256 token	200 OK with claims forwarded	200 OK	PASS	Claims propagated in X-Auth headers
GW-005	Expired JWT rejection	401 Unauthorized	401 Unauthorized	PASS	Token expiry validated
GW-006	Malformed JWT rejection	401 Unauthorized	401 Unauthorized	PASS	No stack trace in response
GW-007	JWT with wrong signing key	401 Unauthorized	401 Unauthorized	PASS	RS256 signature mismatch detected
GW-008	mTLS valid client certificate	200 OK	200 OK	PASS	Certificate chain validated

GW-009	mTLS missing client certificate	403 Forbidden	403 Forbidden	PASS	Connection rejected at TLS layer
GW-010	mTLS expired certificate	403 Forbidden	403 Forbidden	PASS	—
GW-011	Rate limit — per-product (1000/hr)	429 after threshold	429 at 1001st request	PASS	Token bucket refill verified
GW-012	Rate limit — per-partner (5000/hr)	429 after threshold	429 at 5001st request	PASS	Aggregate across products
GW-013	Rate limit — system-wide (500k/hr)	429 after threshold	429 after threshold	PASS	Simulated via load test
GW-014	Rate limit headers present	X-RateLimit-* headers in response	Headers present	PASS	Remaining, Limit, Reset included
GW-015	Circuit breaker OPEN on 5 failures	503 after 5th failure in 30s	503 returned	PASS	State transition logged
GW-016	Circuit breaker HALF-OPEN recovery	Successful request resets to CLOSED	Reset confirmed	PASS	Recovery window = 30s
GW-017	Sandbox mock middleware intercept	Mock response for sandbox keys	Mock data returned	PASS	No upstream call made
GW-018	Sandbox response format consistency	Matches production schema	Schema validated	PASS	All fields present
GW-019	Pilot gate — enabled feature	Request forwarded to upstream	200 OK	PASS	Feature flag checked
GW-020	Pilot gate — disabled feature	404 Not Found	404 Not Found	PASS	Route hidden from partner
GW-021	Session concurrency — single IP	Session created with 60s TTL	TTL set correctly	PASS	Redis key verified
GW-022	Session concurrency — duplicate IP	Previous session invalidated	Old session expired	PASS	Only 1 active session per IP
GW-023	BFF route JWT authentication	JWT required on all BFF paths	401 without token	PASS	Applied to all new BFF routes

4.2 Dev Gateway Tests

Environment: Dev Gateway **Result:** 0/23 — ALL BLOCKED

Test ID	Test Case	Expected	Actual	Status	Notes
GW-D-001	Health check	200 OK	502 Bad Gateway	BLOCKED	PEG-375
GW-D-002	Any authenticated request	200 OK	502 Bad Gateway	BLOCKED	PEG-375
GW-D-003	Rate limiting validation	429 at threshold	502 Bad Gateway	BLOCKED	PEG-375

GW-D-004	Circuit breaker behavior	503 after failures	502 Bad Gateway	BLOCKED	PEG-375
GW-D-005	Sandbox mock responses	Mock data	502 Bad Gateway	BLOCKED	PEG-375
GW-D-006 through GW-D-023	All remaining tests	Various	502 Bad Gateway	BLOCKED	PEG-375

5. Issues Found

Issue ID	Severity	Title	Status	Description
PEG-375	CRITICAL	Partner Gateway returning 502 in dev environment	Open	All requests to the dev partner gateway return 502 Bad Gateway. Upstream services are unreachable. Blocks all dev environment testing. Root cause suspected to be VPS networking or container orchestration misconfiguration after migration from Cloudflare Containers.
PEG-380	Medium	mTLS not enforced in sandbox environment	Open	Sandbox mock middleware bypasses mTLS validation entirely. While this simplifies sandbox testing, it creates a discrepancy between sandbox and production behavior that could mask integration issues during partner onboarding.
PEG-381	Medium	30-second latency spike on first request after circuit breaker reset	Open	When circuit breaker transitions from HALF-OPEN to CLOSED, the first subsequent request experiences approximately 30 seconds of latency. Suspected connection pool cold-start after circuit breaker drains connections.

6. Recommendations

- PEG-375 — Immediate Resolution Required:** The dev gateway 502 is the single highest-impact issue on the platform. Recommend prioritizing VPS networking investigation and establishing a rollback plan to restore dev gateway connectivity.
- Audience Validation:** Document the security implications of disabling JWT audience validation. Implement compensating controls such as issuer validation tightening and request origin verification before production launch.
- mTLS Sandbox Parity (PEG-380):** Consider adding a configurable mTLS simulation mode in sandbox that validates certificate format without requiring a real CA chain. This would catch integration errors earlier.
- Circuit Breaker Latency (PEG-381):** Investigate connection pool pre-warming after circuit breaker recovery. A keep-alive probe during HALF-OPEN state could prevent the cold-start penalty.
- Rate Limit Observability:** Add Prometheus metrics for rate limit bucket consumption to enable proactive capacity planning and partner-specific usage dashboards.

End of Report